

**Design Principles for AI Auditing Systems in Credit Scoring
Under the EU AI Act: A Design Science Literature Review**

Sanket Shrivastava

June 2026

List of Abbreviations

AI	Artificial Intelligence
AML	Anti-Money Laundering
AUC	Area Under the Curve
DCA	Dynamic Compliance Architecture
DP	Design Principle
DSR	Design Science Research
DSRM	Design Science Research Methodology
EU	European Union
LIME	Local Interpretable Model-agnostic Explanations
ML	Machine Learning
RegTech	Regulatory Technology
SHAP	SHapley Additive exPlanations
SLR	Systematic Literature Review
XAI	Explainable Artificial Intelligence

Abstract

Artificial intelligence systems used for credit scoring are classified as high-risk under the European Union AI Act (Regulation EU 2024/1689), triggering stringent obligations across risk management, data governance, transparency, human oversight, and robustness. Despite growing scholarly attention to individual dimensions of AI auditing, the literature lacks integrated, prescriptive design guidance mapping systematically to the Act's legal mandates. This study addresses this gap through the research question: What design principles should guide the development of AI auditing systems for credit scoring to ensure compliance with the EU AI Act? Adopting Design Science Research (Hevner et al., 2004; Peffers et al., 2007) and conducting a structured thematic review of a curated corpus of academic sources, the study identifies five thematic clusters and derives eight Compliance-by-Design principles that collectively define a Dynamic Compliance Architecture (DCA) in which regulatory compliance is a native, continuous, and automated property of the auditing system. The study contributes nascent design theory to the intersection of AI governance, financial regulation, and information systems design.

Keywords: AI auditing, credit scoring, EU AI Act, design principles, design science research, compliance architecture, explainability, fairness

1. Introduction

The financial services industry is undergoing a fundamental transformation driven by artificial intelligence. Machine learning models now underwrite millions of credit decisions annually, with gradient boosting machines such as LightGBM achieving area-under-the-curve (AUC) scores of 0.96, significantly outperforming conventional logistic regression (de Lange et al., 2022). Yet this predictive power introduces opacity: the internal decision logic of these models resists human interpretation, earning them the designation of “black boxes” (Currie et al., 2025). When consumers are denied credit based on algorithmic assessments they can neither see nor contest, the consequences erode institutional trust, deepen existing inequalities, and create accountability gaps that regulators worldwide are now attempting to close (Ferrara, 2024; Currie et al., 2025).

The most significant regulatory response is the European Union Artificial Intelligence Act (Regulation EU 2024/1689), the world’s first comprehensive legal framework for governing AI systems. The Act adopts a risk-based classification, and AI systems evaluating the creditworthiness of natural persons are explicitly designated as high-risk under Annex III, Category 5(b). This classification triggers the Act’s most stringent tier of obligations, spanning risk management throughout the system lifecycle under Article 9, data governance with explicit bias examination under Article 10, automatic logging and record-keeping under Article 12, transparency sufficient for users to interpret outputs under Article 13, human oversight mechanisms under Article 14, and accuracy and robustness under Article 15. Full enforcement of these high-risk requirements begins on 2 August 2026, giving financial institutions a narrow window in which to translate broad legal language into concrete, demonstrable system capabilities.

The urgency of these obligations is compounded by what Currie et al. (2025) term the “pacing problem”—a structural mismatch in which the velocity of AI innovation outstrips the capacity of regulatory systems to respond. Tyagi (2025) reinforces this argument, contending that traditional compliance architectures are fundamentally inadequate for AI-driven financial processes, and identifies three structural tensions that characterise contemporary AI compliance: the innovation-stability paradox, the explainability imperative, and jurisdictional fragmentation. Despite sustained regulatory momentum from 2022 to 2025—spanning the EU AI Act, Basel Committee guidance, the UK Financial Conduct Authority, and the US Office of the Comptroller

of the Currency—most financial institutions still lack practical tools and clear design guidance for auditing credit scoring systems against the Act’s specific requirements (Tyagi, 2025).

A growing body of literature addresses individual dimensions of this challenge. Koshiyama et al. (2024) provide a comprehensive taxonomy of audit dimensions; de Lange et al. (2022) and Hlongwane et al. (2024) show that SHAP-based explanations can be combined with high-accuracy credit models; Bahloul et al. (2026) document that the performance–explainability trade-off is assumed rather than measured; Ferrara (2024) surveys bias sources across data, algorithm, and user-interaction stages; and Bandaru (2025) demonstrates that compliance-native architectures achieve superior auditability. These works are valuable but largely address single components in isolation.

A critical gap therefore persists. The existing literature treats bias detection, explainability, fairness metrics, and compliance architectures separately and apart from the EU AI Act’s specific legal mandates, telling practitioners what to audit but offering limited prescriptive guidance on how to design the auditing system itself. This is fundamentally a design problem (Hevner et al., 2004), not merely a technical or legal one, and it is precisely the kind of problem that Design Science Research is equipped to address.

This paper addresses the gap through the following research question: What design principles should guide the development of AI auditing systems for credit scoring to ensure compliance with the EU AI Act? The study adopts Design Science Research (DSR), a paradigm within information systems that produces prescriptive knowledge about how artifacts ought to be designed to achieve desired goals (Hevner et al., 2004). Within DSR, design principles are a recognised form of design knowledge (Chandra Kruse et al., 2016; Gregor et al., 2020). A number of recent studies adopt precisely this approach for AI-enabled artifacts; the action design research of Herath Pathirannehelage et al. (2025) on AI-augmented decision making is a leading exemplar, and the present study extends that tradition into the regulatory-compliance domain, contributing what the DSR literature terms nascent design theory. The remainder of the paper establishes the theoretical background (Section 2), describes the methodology and thematic analysis (Section 3), presents eight design principles (Section 4), and concludes with theoretical contributions and practical implications (Section 5).

2. Theoretical Background

2.1 Regulatory Compliance and the Pacing Problem

The integration of AI into core financial operations has generated regulatory complexity at a pace that outstrips conventional compliance methodologies (Tyagi, 2025). Currie et al. (2025) conceptualise this as the “pacing problem,” arguing that, unlike earlier technologies such as industrial machinery, contemporary AI systems evolve dynamically—often in ways their creators cannot fully anticipate—rendering traditional regulatory models designed for static technologies increasingly obsolete. The EU AI Act’s risk-stratified architecture represents the most comprehensive attempt to address this challenge to date, with credit scoring designated as high-risk and subject to six mandatory compliance dimensions: lifecycle risk management (Article 9), data governance and bias examination (Article 10), logging and record-keeping (Article 12), transparency (Article 13), human oversight (Article 14), and accuracy and robustness (Article 15). Because these obligations are framed as outcomes rather than as prescribed implementations, the burden of translating them into verifiable system behaviour falls on the institution. The practical consequence is that a credit scoring model approved as compliant at a single point in time may drift out of compliance as its data distribution, feature relationships, or operating environment change, so compliance can no longer be treated as a property that is established once and certified thereafter.

Currie et al. (2025) further argue that AI introduces a new category of risks that extend beyond technical errors and are systemic, evolving, and deeply rooted in institutional dynamics. Their tripartite framework distinguishes functional risks, such as algorithmic bias and opacity; structural risks, including the erosion of democratic norms and market monopolisation; and relational risks, involving power asymmetries between stakeholders. This framework implies that auditing systems must address not only technical compliance but also the institutional and relational contexts in which AI operates. Building on the same diagnosis, Tyagi (2025) proposes the Dynamic Compliance Architecture, constructed on four pillars—Regulatory Horizon Scanning, Adaptive Policy Mapping, Embedded Governance Controls, and Continuous Assurance Loops—and emphasises that compliance must be embedded at the point of system design rather than applied as an ex-post overlay. This conceptual foundation is central to the design principles derived in this study, because it reframes compliance from a documentation exercise into an architectural and operational property of the system.

2.2 Algorithmic Auditing, Fairness, and Bias Detection

Koshiyama et al. (2024) offer one of the most comprehensive taxonomies in the field, conceptualising algorithm auditing as the practice of assessing, monitoring, and assuring an algorithm's safety, legality, and ethics through embedded socio-technical interventions. Their framework identifies fairness, explainability, robustness, and privacy as interdependent audit dimensions and proposes a spectrum of seven levels of auditor access, ranging from process access through checklists to white-box access to full parameters and training data. The access-level spectrum is consequential for design, because the depth of assurance an auditing system can offer is bounded by the level of access it is granted; a system limited to black-box outputs can verify far less than one with white-box access to model internals. Koshiyama et al. (2024) further argue that effective auditing must address all dimensions simultaneously and span five development stages, from problem formulation through deployment. This multi-dimensional perspective is essential because the EU AI Act mandates compliance across several interrelated requirements; an audit examining only fairness would leave transparency and robustness obligations entirely unaddressed.

Bias in credit scoring constitutes one of the most significant compliance risks under Article 10, which explicitly requires the examination of possible biases together with a documented mitigation strategy. Ferrara (2024) provides a comprehensive survey identifying three bias categories—data bias, arising from incomplete or historically discriminatory training data; algorithmic bias, emerging from model architecture; and user-interaction bias, resulting from feedback loops and human interpretation—and argues that mitigation requires holistic approaches spanning pre-processing, in-processing, and post-processing interventions rather than a single technical fix applied at one stage of the pipeline. The salience of this work for auditing design lies in its insistence that bias is not located in any single component but is distributed across the data, the model, and the human context in which decisions are made and acted upon.

Bahloul et al. (2026), synthesising 43 peer-reviewed studies, yield three findings of direct relevance to auditing design. First, no single fairness metric captures all dimensions of fairness, as demographic parity, equalised odds, and disparate impact can yield contradictory conclusions about the same model. Second, the performance–explainability trade-off is largely assumed rather than empirically measured, undermining a common justification for retaining opaque models. Third, the field is shifting from purely technical fairness measures toward regulation-aware

approaches that align metrics with legal categories. Kothandapani (2024) complements this by examining how AI-driven RegTech solutions automate compliance functions across anti-money-laundering, sanctions screening, and transaction monitoring, while noting that persistent gaps remain in longitudinal investigations of bias in automated systems—precisely the kind of evidence that durable, automatically generated audit records would help to produce.

2.3 Explainability and Compliance-Ready Architecture

The Act's transparency requirements under Articles 12 and 13 create a direct demand for explainability mechanisms in credit scoring. de Lange et al. (2022), working with real consumer-loan data from a Norwegian bank, demonstrate that combining LightGBM with SHAP achieves an AUC of 0.96 while simultaneously providing feature-level explanations. SHAP enables two distinct types of explanation: global explanations, which reveal which features are most influential across all predictions, and local explanations, which show which features drove a specific individual's outcome (de Lange et al., 2022). This dual capability is critical for regulatory compliance: global explanations address Article 13's system-level transparency requirement, while local explanations support the individual-level fairness verification demanded by Article 10. Hlongwane et al. (2024) extend this work by developing Shapley-value-based credit scorecards that achieve both interpretability and accuracy superior to traditional logistic regression, directly challenging the assumption that institutions must choose between accuracy and explainability.

At the system-architecture level, the literature converges on the principle that compliance must be an architectural property rather than an external add-on. Bandaru (2025), through a quantitative comparison of 20 compliance-native and 20 conventional AI system deployments, demonstrates statistically significant differences across all compliance metrics, with compliance-native systems also exhibiting lower standard deviations, indicating more predictable and stable compliance behaviour. A strong negative correlation ($r = -0.72$) between architectural control density and compliance-incident frequency confirms that embedding compliance structurally reduces risk (Bandaru, 2025). Gajula (2025) complements this with enterprise-architecture principles, demonstrating how microservices-based design enables modular, real-time AI integration and the insertion of monitoring and governance controls at well-defined service boundaries. Together, these works establish empirically that the transition from compliance as periodic documentation to compliance as embedded architecture is measurably superior (Bandaru, 2025).

Taken as a whole, the substantive literature points in a consistent direction: the requirements of the EU AI Act are interdependent, dynamic, and structural, and they therefore cannot be satisfied by isolated, point-in-time, manually produced assessments. A further pattern, latent across these works, is that explainability and fairness are not separable concerns: the same feature-attribution evidence that satisfies a transparency obligation also reveals whether protected attributes are influencing outcomes, so a well-designed explanation layer simultaneously serves Article 13 and supports Article 10. What the literature does not yet provide is a prescriptive bridge from these observations to the design of the auditing artifact itself—a bridge that the design-science tradition is specifically constructed to build.

2.4 Design Science Research and the Design-Principles Approach

Design Science Research (DSR) provides the methodological lineage for translating the observations above into prescriptive guidance. The foundational statement of the paradigm by Hevner et al. (2004) positions design science as the creation and evaluation of artifacts intended to solve identified organisational problems, complementing the behavioural-science tradition that seeks to explain and predict. Peffers et al. (2007) operationalise this paradigm into a six-activity Design Science Research Methodology (DSRM) that has become the dominant process model in the field. Within this lineage, a distinct stream of scholarship focuses specifically on design principles as the unit of prescriptive knowledge: Chandra Kruse et al. (2016) examine how design principles are used and reused, Gregor et al. (2020) provide an anatomy of a design principle that separates aim, context, mechanism, and rationale, and Iivari et al. (2021) propose criteria for evaluating the reusability of design principles by their intended community of practitioners.

Several recent studies adopt exactly this approach and provide the closest methodological models for the present work. Herath Pathirannehelage et al. (2025), through an action design research study, derive design principles for AI-augmented decision making, demonstrating how prescriptive design knowledge can be articulated for AI-enabled artifacts and subsequently subjected to practitioner evaluation. Their study addresses organisational challenges in deploying AI within a co-creation business model; the present study addresses the distinct but adjacent challenge of designing auditing systems that verify the regulatory compliance of deployed AI. By locating the work within this design-principles tradition, the study is able to treat the EU AI Act's requirements not as abstract ethical aspirations but as boundary conditions and design goals from

which concrete, testable principles can be derived—an orientation that the remainder of the paper develops in full.

3. Research Methodology

3.1 Design Science Research Positioning

This study employs Design Science Research (DSR) as its methodological foundation. DSR is a research paradigm within information systems that produces prescriptive knowledge—knowledge about how things ought to be designed to achieve desired goals—through the creation and evaluation of artifacts that solve identified problems (Hevner et al., 2004). The Design Science Research Methodology (DSRM) proposed by Peffers et al. (2007) structures the research process into six activities: problem identification and motivation, definition of objectives, design and development, demonstration, evaluation, and communication.

Within DSR, design principles are a well-established form of prescriptive design knowledge. Gregor et al. (2020) provide a comprehensive anatomy of design principles, identifying their core components as the aim (what the principle seeks to achieve), the context (the boundary conditions under which it applies), the mechanism (how the principle operates), and the rationale (the justification grounded in theory or evidence). Chandra Kruse et al. (2016) further argue that design principles should be formulated in terms of materiality, action, and boundary conditions. Following these conceptualisations, each principle in this study is formulated using an explicit structure: “For [context/boundary], implement [mechanism/action] so that [aim], because [rationale/justification]” (Gregor et al., 2020; Chandra Kruse et al., 2016). This study executes the first three DSRM activities: identifying the compliance gap in AI auditing for credit scoring, defining what an effective auditing system must achieve by mapping regulatory articles to technical requirements, and deriving the design principles themselves. The principles constitute nascent design theory (Hevner et al., 2004) that future research can operationalise through the remaining DSRM activities.

3.2 Literature Search and Selection

The literature search was conducted primarily through Google Scholar, supplemented by targeted searches in the ACM Digital Library, SpringerLink, and Elsevier ScienceDirect. The search was guided by five keyword clusters: “EU AI Act” AND “credit scoring” AND

“compliance”; “algorithm auditing” AND “fairness” AND “framework”; “explainability” AND “SHAP” AND “credit”; “responsible AI” AND “design principles” AND “compliance architecture”; and “Design Science Research” AND “information systems.” Journal quality was verified using the Rapid Journal Quality Check browser extension, with sources prioritised from ABDC A* and A-ranked, SJR Q1 and Q2, VHB-ranked, and CORE-ranked outlets. The search covered publications from 2020 to 2026, with exceptions made for foundational DSR works. After screening for relevance and quality, twelve core sources were retained for in-depth thematic analysis—comprising studies on AI auditing, fairness, explainability, compliance architecture, and design-science exemplars—supplemented by foundational methodology and design-principle works (Hevner et al., 2004; Peffers et al., 2007; Gregor et al., 2020; Chandra Kruse et al., 2016; Iivari et al., 2021). The full source-analysis matrix is presented in Appendix A.

3.3 Thematic Analysis Procedure

The selected sources were analysed using thematic analysis following a structured coding procedure. Each paper was read in full and coded along four dimensions: main concepts and theories discussed, findings relevant to auditing-system design, regulatory requirements addressed, and explicit or implicit design recommendations. These initial codes were grouped into higher-order themes through iterative comparison, following an abductive logic that moved between the empirical codes and the theoretical framing provided by DSR and the EU AI Act’s regulatory structure. Five thematic clusters emerged, summarised in Table 1. Within each theme, prescriptive statements were identified in the literature or derived from identified gaps and regulatory requirements, and these were then formulated as design principles following the structure recommended by Gregor et al. (2020).

Table 1

Thematic Analysis of the Reviewed Literature

Theme	Description	Papers (Sources)
Regulatory traceability and lifecycle demands	The need for direct, verifiable correspondence between auditing-system components and specific legal articles, sustained continuously across the system lifecycle rather than at a single point in time.	Tyagi (2025); Currie et al. (2025); Bandaru (2025)
Multi-dimensional and	Effective auditing must evaluate several interdependent dimensions simultaneously and	Koshiyama et al. (2024); Currie et al. (2025); Kothandapani (2024)

Theme	Description	Papers (Sources)
automated auditing	operate at a scale and frequency that only automation can sustain under post-market monitoring.	
Fairness, bias, and subgroup accountability	Bias is distributed across data, algorithm, and human context; demonstrating fairness requires disaggregated, multi-metric evaluation and documented mitigation evidence.	Bahloul et al. (2026); Ferrara (2024); Kothandapani (2024)
Fairness-through-explainability convergence	Explainability operates not only as transparency but as the primary vehicle through which fairness is detected and enforced, via complementary global and local explanations.	de Lange et al. (2022); Hlongwane et al. (2024); Bahloul et al. (2026)
Architectural embedding of compliance	Compliance capabilities must be structural, native components of the system architecture so that audit evidence is produced as a by-product of normal operation.	Bandaru (2025); Gajula (2025); Tyagi (2025); Currie et al. (2025)

4. Findings: Design Principles

The thematic synthesis yields eight Compliance-by-Design principles, each formulated following the anatomy advanced by Gregor et al. (2020) and Chandra Kruse et al. (2016) and specifying context, mechanism, aim, and rationale. The interpretation in this section is the author’s own derivation from the thematic clusters; supporting sources are cited only where a principle rests directly on a specific empirical claim. Together, the eight principles define a Dynamic Compliance Architecture in which regulatory compliance is native, continuous, and automated.

Principle 1: Regulatory Traceability

Because the EU AI Act imposes obligations through distinct articles, an auditing system whose outputs cannot be mapped back to those articles cannot demonstrate compliance in a legally defensible form. Organising the system so that each module answers to a named article turns the audit trail itself into the evidence of conformity.

DP1 — Regulatory Traceability: For auditing systems serving high-risk AI under the EU AI Act, implement a module-per-article architecture so that every audit output maps directly to a specific regulatory requirement, because legal defensibility requires a demonstrable correspondence between system capabilities and legal obligations.

Principle 2: Lifecycle Coverage

A point-in-time assessment cannot account for AI systems that learn and adapt after deployment, since model behaviour and input distributions change over time and compliance established at certification can quietly lapse. The auditing system must therefore operate continuously across the full lifecycle, converting compliance from a discrete event into an ongoing condition.

DP2 — Lifecycle Coverage: For credit scoring AI subject to post-market monitoring, implement continuous auditing across the full system lifecycle so that compliance is maintained dynamically, because ongoing risk management is mandated and one-time assessments are insufficient for evolving AI systems.

Principle 3: Multi-dimensional Assessment

Compliance under the Act is not reducible to any single property; an audit that measures only fairness leaves transparency, data quality, robustness, and human oversight unverified. The auditing system must therefore assess these dimensions together, since a deficiency in one cannot be offset by strength in another.

DP3 — Multi-dimensional Assessment: For high-risk AI systems under the EU AI Act, implement simultaneous evaluation across fairness, transparency, data quality, robustness, and human oversight, because the Act mandates compliance across interrelated requirements and isolated audits produce misleading results (Koshiyama et al., 2024).

Principle 4: Automation

The frequency demanded by continuous, multi-dimensional auditing exceeds what manual review can sustain at scale. Data collection, metric computation, and report generation must therefore be automated, both to keep pace and to remove the inconsistency that manual processes introduce.

DP4 — Automation: For credit scoring systems subject to post-market monitoring, automate data collection, metric computation, and compliance-report generation, because continuous surveillance at scale requires a frequency that manual processes cannot sustain (Kothandapani, 2024).

Principle 5: Subgroup-aware Fairness

An aggregate fairness score can conceal substantial disparities between demographic groups, and no single metric captures every dimension of fairness. Demonstrating compliance with Article 10 therefore requires evaluation that is disaggregated across protected groups and computed with multiple, potentially divergent metrics, so that subgroup harms are surfaced rather than averaged away.

DP5 — Subgroup-aware Fairness: For credit scoring AI subject to Article 10, implement disaggregated evaluation across protected demographic groups using multiple fairness metrics, because aggregate metrics mask significant subgroup disparities (Bahlool et al., 2026).

Principle 6: Bias Documentation

Article 10 requires not only that bias be examined but that a mitigation strategy be documented. The auditing system should therefore treat the record of what was examined, found, and done as a first-class output, generated automatically rather than reconstructed after the fact, which also enables the longitudinal study of bias the literature finds lacking.

DP6 — Bias Documentation: For high-risk AI systems under Article 10, automatically generate documented evidence of the bias examination conducted, the biases found, and the mitigation measures applied, because the Act requires a documented mitigation strategy as a standard compliance output.

Principle 7: Dual-layer Explainability

Explainability serves two regulatory purposes at once: global explanations reveal which features drive the model across all decisions and satisfy system-level transparency, while local explanations justify an individual outcome and support fairness checks. Because the same machinery surfaces whether protected attributes influence predictions, explainability and fairness should be designed as one integrated capability rather than two separate modules.

DP7 — Dual-layer Explainability: For credit scoring AI subject to Articles 12 and 13, implement both global explanations (model-level feature importance) and local explanations (individual decision justifications) so that different stakeholder needs are

served simultaneously, because global and local explanations serve complementary compliance purposes (de Lange et al., 2022).

Principle 8: Compliance by Architecture

The preceding principles converge on a single structural commitment: compliance must be built into the architecture rather than bolted on. When auditability, traceability, and evidence generation are native components, audit evidence is produced as a by-product of ordinary operation and the system can absorb regulatory change without redesign. The empirical superiority of compliance-native architectures makes this the overarching principle that organises the other seven.

DP8 — Compliance by Architecture: For regulated AI systems in financial services, embed compliance requirements as native structural components so that audit evidence is generated automatically as a by-product of normal operation, because compliance-native architectures empirically outperform conventional systems (Bandaru, 2025).

4.1 Synthesis: The Consolidated Design-Principles Framework

Table 2 consolidates the eight principles, linking each to its description, its principal sources, and the EU AI Act articles it operationalises.

Table 2

Consolidated Design Principles for AI Auditing Systems in Credit Scoring

Principle	Description	Key Sources	EU AI Act Articles
Regulatory Traceability	Module-per-article architecture mapping audit outputs to specific requirements	Tyagi (2025); Bandaru (2025)	All Articles
Lifecycle Coverage	Continuous auditing across the full system lifecycle	Currie et al. (2025); Tyagi (2025)	Art. 9, 72
Multi-dimensional Assessment	Simultaneous evaluation across fairness, transparency, robustness, oversight	Koshiyama et al. (2024); Currie et al. (2025)	Art. 9, 10, 13, 15
Automation	Automated metric computation and compliance-report generation	Koshiyama et al. (2024); Kothandapani (2024)	Art. 12, 72
Subgroup-aware Fairness	Disaggregated evaluation across protected groups, multiple metrics	Bahloul et al. (2026); Ferrara (2024)	Art. 10

Principle	Description	Key Sources	EU AI Act Articles
Bias Documentation	Automated bias-examination evidence with mitigation log	Bahloul et al. (2026); Ferrara (2024)	Art. 10
Dual-layer Explainability	Global and local explanations for different stakeholders	de Lange et al. (2022); Hlongwane et al. (2024)	Art. 12, 13
Compliance by Architecture	Compliance as native structural components	Bandaru (2025); Currie et al. (2025); Tyagi (2025)	All Articles

The eight principles collectively define a Dynamic Compliance Architecture in which regulatory compliance is native, continuous, and automated. Regulatory traceability (DP1) supplies the organising logic, lifecycle coverage (DP2) defines the temporal scope, and multi-dimensional assessment (DP3) and automation (DP4) establish the substantive scope and operational feasibility. Subgroup-aware fairness (DP5) and bias documentation (DP6) operationalise Article 10, dual-layer explainability (DP7) unifies the Act’s transparency and fairness objectives, and compliance by architecture (DP8) provides the overarching structure within which the others are realised. Together they address the gap identified in the introduction: while the Act specifies what credit scoring AI must comply with, these principles specify how an auditing system should be designed to verify that compliance.

5. Conclusion

5.1 Theoretical Contributions

This study makes three theoretical contributions to the information-systems design literature. First, it demonstrates the applicability of DSR methodology to AI regulatory compliance, producing design principles as nascent design theory following the formulation structure advocated by Gregor et al. (2020) and Chandra Kruse et al. (2016). In doing so it extends the design-science tradition exemplified by Herath Pathirannehelage et al. (2025), who derived design principles for AI-augmented decision making through action design research, into the regulatory-compliance domain. Where their study addressed organisational challenges in deploying AI within a co-creation business model, the present study addresses the distinct challenge of designing auditing systems that verify the regulatory compliance of deployed AI.

Second, the study bridges the persistent gap between abstract AI-ethics principles and concrete system-design guidance that multiple scholars identify as a critical challenge (Koshiyama

et al., 2024; Ferrara, 2024). By deriving design principles from the EU AI Act’s specific articles rather than from general ethical frameworks, it provides guidance that is immediately traceable to legal obligations. This regulatory-first approach contrasts with the dominant pattern in the literature, where scholars begin with ethical principles and attempt to translate them into technical requirements. Third, the five thematic clusters synthesise previously disconnected streams—algorithmic auditing, explainability, fairness, compliance architecture, and AI regulation—into an integrated framework. The convergence between explainability and fairness captured in Principle 7 is particularly noteworthy, revealing that explanation techniques serve a dual compliance function that has not previously been articulated as a unified design requirement.

5.2 Practical Implications

For financial institutions facing the August 2026 enforcement deadline, the eight principles function as a concrete design checklist, useful both for building in-house auditing capabilities and for evaluating third-party compliance tools. A procurement team can interrogate a candidate tool against each principle in turn: does it map its outputs to specific articles (DP1); does it operate continuously rather than at a single point in time (DP2); does it assess all of the mandated dimensions rather than fairness alone (DP3); does it automate metric computation and reporting (DP4); does it disaggregate fairness across protected groups using more than one metric (DP5); does it generate durable bias-examination evidence (DP6); does it provide both global and local explanations (DP7); and is compliance native to its architecture or merely an overlay (DP8)? A tool that fails one of these tests signals a corresponding gap in regulatory coverage; a tool that does not support subgroup-aware fairness evaluation, for example, is unlikely to satisfy Article 10’s explicit requirement for bias examination.

For RegTech vendors, the principles define a product design roadmap and a basis for differentiation. The empirical evidence that compliance-native architectures outperform conventional ones—scoring 91.4 versus 68.2 on auditability (Bandaru, 2025)—implies that tools designed as add-on compliance layers will tend to underperform those that embed regulatory requirements natively. Vendors that treat traceability, continuous monitoring, and automated evidence generation as foundational rather than as features added late in development are therefore better positioned to deliver tools that withstand regulatory scrutiny. The principles also suggest a sequencing: because Principle 8 organises the others, architectural decisions about where

compliance evidence is produced should precede, not follow, decisions about individual fairness or explainability metrics.

For regulators and supervisory authorities, the principles offer a structured lens for distinguishing substantive compliance from cosmetic compliance—a distinction that becomes operationally meaningful as enforcement begins. An institution that can demonstrate article-level traceability, continuous lifecycle coverage, and automatically generated bias documentation is presenting auditable evidence of conformity; an institution relying on periodic manual reviews and aggregate fairness scores is not, even if its paperwork appears complete. In this way the principles provide supervisors with a vocabulary for assessing the design of an auditing capability, not merely its documented outputs, and they may help inform the technical standards that remain under development as the Act moves into force.

5.3 Conclusion

This study set out to identify design principles for AI auditing systems in credit scoring under the EU AI Act, and it derived eight Compliance-by-Design principles that together define a Dynamic Compliance Architecture in which compliance is a structural property of the auditing system rather than an external overlay. The principles are derived from literature synthesis rather than empirical implementation, so the demonstration and evaluation activities of the DSRM cycle remain to be completed; future work should operationalise the principles in a working audit pipeline applied to real credit scoring data and subject them to practitioner evaluation of the kind proposed by Iivari et al. (2021). With that caveat acknowledged, the eight principles offer a grounded foundation for building auditing systems that are simultaneously high-performing, legally defensible, and socially fair as enforcement of the Act begins.

References

- Bahlool, R., Nauck, D., & Oberste-Berghaus, J. (2026). Performance, fairness, and explainability in AI-based credit scoring: A systematic literature review. *Journal of Risk and Financial Management*, 19(2), 104. <https://doi.org/10.3390/jrfm19020104>
- Bandaru, N. (2025). Architecting compliance ready artificial intelligence for regulated digital systems. *International Journal of Research Publications in Engineering, Technology and Management*, 8(4), 12463–12471. <https://www.ijrpetm.com/index.php/IJRPETM/article/view/347>
- Chandra Kruse, L., Seidel, S., & Purao, S. (2016). Making use of design principles. In *Tackling Society's Grand Challenges with Design Science: DESRIST 2016* (pp. 37–51). Springer. https://doi.org/10.1007/978-3-319-39294-3_3
- Currie, W. L., Leimeister, J. M., Schlagwein, D., & Willcocks, L. (2025). Rethinking technology regulation in the age of AI risks. *Journal of Information Technology*, 40(3), 236–245. <https://doi.org/10.1177/02683962251378815>
- de Lange, P. E., Melsom, B., Venneroed, C. B., & Westgaard, S. (2022). Explainable AI for credit assessment in banks. *Journal of Risk and Financial Management*, 15(12), 556. <https://doi.org/10.3390/jrfm15120556>
- Ferrara, E. (2024). Fairness and bias in artificial intelligence: A brief survey of sources, impacts, and mitigation strategies. *Sci*, 6(1), 3. <https://doi.org/10.3390/sci6010003>
- Gajula, S. (2025). Enterprise architecture for AI integration in financial services: A framework for risk management, customer experience, and operational efficiency. *International Research Journal of Modernization in Engineering, Technology and Science*, 7(3). <https://www.irjmets.com>
- Gregor, S., Kruse, L. C., & Seidel, S. (2020). Research perspectives: The anatomy of a design principle. *Journal of the Association for Information Systems*, 21(6), 1622–1652. <https://doi.org/10.17705/1jais.00649>
- Herath Pathirannehelage, S., Shrestha, Y. R., & von Krogh, G. (2025). Design principles for artificial intelligence-augmented decision making: An action design research study. *European Journal of Information Systems*, 34(2), 207–229. <https://doi.org/10.1080/0960085X.2024.2330402>

- Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75–105. <https://doi.org/10.2307/25148625>
- Hlongwane, R., Ramabao, K., & Mongwe, W. (2024). A novel framework for enhancing transparency in credit scoring: Leveraging Shapley values for interpretable credit scorecards. *PLoS ONE*, 19(8), e0308718. <https://doi.org/10.1371/journal.pone.0308718>
- Iivari, J., Rotvit Perlt Hansen, M., & Haj-Bolouri, A. (2021). A proposal for minimum reusability evaluation of design principles. *European Journal of Information Systems*, 30(3), 286–303. <https://doi.org/10.1080/0960085X.2020.1793697>
- Koshiyama, A., Kazim, E., Treleaven, P., Rai, P., Szpruch, L., Pavey, G., Ahamat, G., Leutner, F., Goebel, R., Knight, A., Adams, J., Hitrova, C., Barnett, J., Nachev, P., Barber, D., Chamorro-Premuzic, T., Klemmer, K., Gregorovic, M., Khan, S., ... Chatterjee, S. (2024). Towards algorithm auditing. *Royal Society Open Science*, 11(5), 230859. <https://doi.org/10.1098/rsos.230859>
- Kothandapani, H. P. (2024). Automating financial compliance with AI: A new era in regulatory technology. *International Journal of Science and Research Archive*, 11(1), 2646–2659. <https://doi.org/10.30574/ijrsra.2024.11.1.0040>
- Peppers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems*, 24(3), 45–77. <https://doi.org/10.2753/MIS0742-1222240302>
- Tyagi, N. (2025). The compliance horizon: Anticipating regulatory change in financial services and artificial intelligence. *International Journal of Research and Applied Innovations*, 8(2), 11227–11232. <https://doi.org/10.15662/IJRAI.2025.0802011>

Appendix A: Source Analysis Matrix

Table A1

Source Analysis Matrix

Source	Year	Main Concepts & Theories	Main Findings	Relevance to RQ
Tyagi	2025	DCA; regulatory lag; innovation-stability paradox; jurisdictional fragmentation	Traditional compliance cannot keep pace with AI; proactive horizon scanning needed	DCA model for anticipatory governance; four-pillar framework
Bandaru	2025	Compliance-by-design; auditability; decision traceability; model reproducibility	Compliance-native architectures score 91.4 vs. 68.2; lower variance	Quantifies architectural compliance superiority
Currie et al.	2025	Pacing problem; functional, structural, relational risks; regulatory theory	AI opacity necessitates risk-informed governance; tripartite framework	Risk categorisation for regulatory design
Koshiyama et al.	2024	Algorithm auditing; 5 development stages; 7 access levels; multi-dimensional	Auditing requires multi-stakeholder, multi-dimensional approach	Auditing protocols and mitigation techniques
Ferrara	2024	Bias sources (data, algorithm, user); pre/in/post-processing mitigation	Bias requires holistic, interdisciplinary mitigation	Three-category bias framework
Bahloul et al.	2026	SLR of 43 studies; performance–fairness–explainability; regulation-aware shift	Trade-off is assumed not empirical; no single fairness metric suffices	Synthesises fairness and explainability evidence
de Lange et al.	2022	XAI; LightGBM; SHAP; global/local explanations; imbalanced classification	AUC 0.96 with SHAP; global and local explanations serve dual purposes	Performance–explainability compatibility
Hlongwane et al.	2024	SHAP; one-hot encoding; Shapley-value scorecards; tree-based models	Advanced models produce scorecards superior to logistic regression	Interpretability and accuracy co-optimisation

Source	Year	Main Concepts & Theories	Main Findings	Relevance to RQ
Gajula	2025	Enterprise architecture; microservices; anomaly detection; real-time integration	EA provides structural blueprint for AI–legacy integration	Modular architecture and organisational readiness
Kothandapani	2024	RegTech; ML in AML/sanctions; predictive analytics; automated compliance	AI improves compliance accuracy; gap in longitudinal bias studies	Automation of compliance and ethical gaps
Herath Pathirannehelage et al.	2025	Action design research; design principles for AI-augmented decision making	Demonstrates derivation and practitioner evaluation of AI design principles	Methodological exemplar for the DSR design-principles approach
Gregor et al.	2020	Anatomy of a design principle: aim, context, mechanism, rationale	Provides a formal structure for stating prescriptive design knowledge	Formulation template for the derived principles